

Análisis y Planificación del Pentest para Aurora Market

Nombre completo: Veronica Fernandes

Fecha de creación: 05-09-2026

Revisado: 12-'92026

1. Objetivos del Pentest

Justificación de Negocio

Realizar un Pentest (Prueba de Penetración) a la infraestructura y plataforma web de **Aurora Market** se trata de una inversión estratégica orientada a garantizar la resiliencia operativa y la sostenibilidad del negocio. Como e-commerce, la confianza de los usuarios es el activo más valioso de la empresa: una brecha de seguridad que exponga datos personales, tarjetas de crédito o credenciales de acceso destruye de inmediato la reputación de la marca, además de ser objeto de sanciones regulatorias y pérdidas financieras por fraude.

El propósito fundamental de esta evaluación es simular el comportamiento de un atacante real bajo un marco ético y controlado. Mediante este ejercicio se busca comprender con precisión la **superficie de ataque real**, identificando no solo fallos técnicos en el código o configuraciones defectuosas en los servidores, sino también **debilidades en la lógica de negocio** (como la manipulación de precios, la evasión de pasarelas de pago o la escalada de privilegios entre cuentas de usuario).

El valor directo que esta evaluación aporta a Aurora Market se resume en tres pilares:

1. **Visibilidad Real del Riesgo:** Permite a la dirección y al equipo de TI conocer el estado real de sus defensas desde la perspectiva de un ciberdelincuente, superando la falsa sensación de seguridad que generan los escaneos automatizados pasivos.

Identificar y evaluar vulnerabilidades en la aplicación web de Aurora Market que puedan comprometer la confidencialidad de los datos de los clientes.

2. **Protección de Ingresos y Continuidad Operativa:** Previene incidentes que puedan provocar la caída de la tienda durante picos de venta, robo de fondos o secuestro de datos (Ransomware).

Evaluar la resistencia de los mecanismos de pago e infraestructura transaccional para prevenir fraudes, robo de credenciales de pago o manipulación de pedidos.

3. **Plan de Remediación Priorizado y Eficiente:** Al finalizar la prueba, Aurora Market no recibirá únicamente una lista de errores, sino un mapa de ruta técnico y ejecutivo categorizado por nivel de criticidad. Esto permite a los desarrolladores y administradores de sistemas corregir primero las fallas de mayor impacto con un uso óptimo de los recursos.

Proporcionar un informe ejecutivo y técnico con recomendaciones claras de remediación para elevar el nivel general de ciberseguridad y proteger la reputación de Aurora Market.

2. Alcance

Sí se evaluará (Dentro del alcance):

- Aplicación web principal de comercio electrónico <https://www.auroramarket.com>.
- Servidor web e infraestructura cloud asociada directamente con el entorno de pruebas/staging asignado.
- Formularios de inicio de sesión, registro, recuperación de contraseña y procesos de checkout.
- API REST y endpoints que gestionan autenticación, catálogo, carrito de compras y la integración con la pasarela de pagos.
- Perfiles de usuarios (clientes, administradores, soporte) y gestión de roles.

Fuera del alcance:

- Ataques de Denegación de Servicio (DoS / DDoS) que puedan interrumpir la continuidad del negocio.
- Ingeniería social o phishing dirigido a empleados o clientes de Aurora Market.
- Entornos de producción críticos durante horarios de alta demanda sin coordinación previa.
- Seguridad física de los centros de datos u oficinas.

Estrategia de Recopilación de Información: Fuentes y Herramientas

Para construir una radiografía precisa de la plataforma se utilizará una **combinación de fuentes abiertas (OSINT) y fuentes internas**, aprovechando la modalidad Gray-Box acordada:

1. Fuentes Abiertas (OSINT - Inteligencia de Fuentes Abiertas):

- **Objetivo:** Descubrir información expuesta involuntariamente en internet sin interactuar de forma agresiva con la plataforma.
- **Métodos:** Búsqueda de subdominios olvidados o entornos de prueba expuestos (dev.auroramarket.com, test.auroramarket.com), análisis de registros DNS, fugas de credenciales en repositorios públicos (GitHub/GitLab) y metadatos alojados en la web.

2. Fuentes Internas (Modalidad Gray-Box):

- **Objetivo:** Evaluar la seguridad desde la perspectiva de un usuario que ya posee un nivel de acceso a la plataforma.
- **Métodos:** Uso de credenciales de prueba provistas por Aurora Market (cuentas con rol de cliente básico, usuario con privilegios intermedios y administrador), acceso a documentación de soporte de la API y mapas de arquitectura básica.

Propósito de Herramientas Clave en el Escenario

- **Nmap:** Es la herramienta estándar para el escaneo de red y puertos. Su propósito dentro de Aurora Market es identificar qué puertos están abiertos (e.g., 80, 443, 22, 3306), qué servicios están escuchando en ellos y qué versiones exactas de software (servidor web Nginx/Apache, motor de base de datos) se están ejecutando, permitiendo detectar componentes desactualizados con vulnerabilidades conocidas.
- **OWASP ZAP (Zed Attack Proxy) / Burp Suite:** Actúan como un proxy local que intercepta, analiza y modifica el tráfico HTTP/HTTPS entre el navegador y los servidores de Aurora Market. Su propósito es inspeccionar las peticiones a fondo, manipular parámetros en tiempo real (por ejemplo, alterar montos en las solicitudes de compra o tokens de sesión) y automatizar el descubrimiento de fallos web como XSS o SQLi.

3. Autorización y Condiciones

Permisos requeridos:

- Carta de autorización formal firmada por la gerencia/dirección de Aurora Market (RoE - Rules of Engagement).
- Whitelisting de las direcciones IP de origen del equipo auditor en los Firewalls/WAF u otra tecnología protectiva.
- Creación de cuentas de prueba con diferentes roles de usuario (cliente estándar, administrador, etc.) en el entorno de staging.
- Persona de contacto técnico asignada para emergencias durante la ejecución de las pruebas.
- NDA firmado por ambas partes antes del inicio de las actividades

Condiciones acordadas:

- **Ventanas de ejecución:** Pruebas intensivas realizadas exclusivamente fuera del horario pico de la plataforma.
- **Notificación de vulnerabilidades críticas:** Notificación inmediata (menor a 2 horas) si se descubre una vulnerabilidad de severidad Crítica o Alta que ponga en riesgo inminente el sistema.
- **Manejo de datos sensibles:** Todos los datos de prueba capturados durante el pentest serán cifrados y destruidos tras la entrega del informe final.

Horarios Propuestos y Justificación

Considerando las operaciones comerciales de Aurora Market, las pruebas se clasificarán según su grado de invasividad:

Ventana Horaria	Tipo de Pruebas Permitidas	Justificación Operativa
Horario Hábil	Reconocimiento pasivo,	No generan carga de procesamiento en

Ventana Horaria	Tipo de Pruebas Permitidas	Justificación Operativa
(09:00 - 18:00 hs)	OSINT, navegación manual e inspección de peticiones no destructivas.	los servidores ni riesgo de interrupción, permitiendo interactuar con el equipo de TI para dudas sobre la arquitectura.
Horario Nocturno / De baja demanda (23:00 - 05:00 hs)	Escaneos automatizados intensivos (Nmap, ZAP), pruebas de validación de entradas y fase de Explotación.	Es la franja con el menor volumen de compras por parte de clientes reales. En caso de una inestabilidad no planificada en la base de datos o el servidor, el impacto económico y operativo sobre Aurora Market se minimiza drásticamente.

4. Tipo de Pentest

- **Tipo de Pentest Elegido: Gray-Box (Caja Gris)**
- **Justificación de la Elección:** El enfoque Gray-Box simula la perspectiva de un atacante con conocimiento parcial o un usuario autenticado (como un cliente con cuenta o un empleado con privilegios limitados). Esto permite equilibrar la eficiencia del tiempo de auditoría con la cobertura de pruebas, garantizando la detección de fallos de escalación de privilegios y lógica de negocio sin gastar excesivo tiempo en el reconocimiento inicial a ciegas. La Caja Gris simula de forma realista la amenaza de un usuario autenticado (cliente malintencionado) o un atacante que logró credenciales básicas, permitiendo verificar si desde una cuenta estándar es posible escalar privilegios, ver las órdenes de otros clientes (IDOR) o alterar transacciones comerciales.

5. Planificación

- **Objetivos:** Definir las metas de evaluación técnica alineadas al negocio de e-commerce de Aurora Market.
- **Alcance:** Delimitar con precisión los activos, dominios e IP objeto de la auditoría.
- **Permisos y Condiciones:** Formalizar la documentación legal (NDA, autorización explícita) y canales de comunicación.
- **Metodología a utilizar:** Aplicar estándares reconocidos como OWASP Testing Guide (OTGv4) para aplicaciones web.
- **Recopilación de información previa:** Obtener documentación de arquitectura básica, endpoints de API clave y credenciales de prueba.
- **Recursos necesarios:** Herramientas especializadas (Burp Suite, Nmap, Metasploit), infraestructura de pruebas aislada e IP dedicada.

- **Programación del Pentest:** Establecer un cronograma claro detallando fechas para cada fase (Reconocimiento, Explotación, Reporte).

6. Fases del Pentest

Abordaje Técnico

En esta sección se detalla el enfoque metódico que se seguirá durante la evaluación, estableciendo qué se busca, cómo se ejecuta y qué herramientas intervienen en cada etapa.

Fase 1: Reconocimiento

- **Objetivo:** Mapear la superficie expuesta e identificar todos los posibles puntos de entrada hacia la infraestructura de Aurora Market antes de realizar cualquier intento de ataque.
- **Metodología y Acciones:**
 - **Enumeración DNS y de Subdominios:** Descubrimiento de servicios web asociados utilizando herramientas como sublist3r o Amass.
 - **Análisis de Tecnologías Web:** Identificación de lenguajes de programación, servidores web, bibliotecas JavaScript y CMS mediante componentes como WhatWeb.
 - **Escaneo de Puertos y Servicios:** Descubrimiento de servicios activos sobre las IP del alcance mediante **Nmap** (ejecutando comandos de detección de versión nmap -sV -sC -p- <IP_Target>). Se busca determinar si existen puertos administrativos (ej. SSH 22, FTP 21, Bases de Datos 3306/5432) expuestos a internet sin restricciones.
 - **Mapeo de la Aplicación:** Navegación metódica a través del sitio web con Burp Suite para mapear todos los endpoints de la API, campos de formulario, rutas de subida de archivos y parámetros de URL.

Fase 2: Análisis de Vulnerabilidades

- **Objetivo:** Detectar, categorizar y priorizar debilidades de seguridad o fallos de configuración en las tecnologías y la lógica identificadas en la fase previa.
- **Herramientas y Propósito:**
 - **OWASP ZAP / Burp Suite Scanner:** Realización de un escaneo automatizado para detectar vulnerabilidades web comunes (Cross-Site Scripting, Inyecciones SQL básicas, cabeceras de seguridad ausentes, componentes desactualizados).
 - **Análisis Manual Estructurado:** Se realizarán pruebas manuales para identificar fallos de control de acceso (IDOR), manipulación de parámetros de precios en las solicitudes HTTP del carrito de compras y debilidades en la gestión de sesiones.

Fase 3: Explotación

- **Objetivo:** Validar en la práctica las vulnerabilidades encontradas en la fase anterior para confirmar si son explotables en el mundo real, determinando su impacto real sin comprometer la estabilidad del sistema.
- **Metodología:**
 - Ejecución controlada de pruebas de concepto (PoC). Por ejemplo, si se detecta un posible fallo de inyección SQL mediante **sqlmap** o Burp Suite, se prueba la extracción de un dato no sensible (como la versión de la base de datos) para confirmar la vulnerabilidad sin alterar ni destruir la información de la base de datos de Aurora Market.

Fase 4: Post-Explotación

- **Objetivo:** Determinar las consecuencias de un compromiso exitoso evaluando qué nivel de acceso adicional podría obtener un atacante dentro de la red corporativa.
- **Metodología:**
 - Evaluación de la escalada de privilegios (de un usuario cliente hacia un rol de administrador del e-commerce).
 - Análisis de la capacidad de mover lateralmente la sesión o acceder a datos confidenciales en repositorios internos (tablas de usuarios, historial de transacciones).
 - *Nota:* Toda acción en esta fase se ejecuta bajo estrictas limitaciones para garantizar que no se modifiquen, borren ni filtren datos reales de la empresa.

Fase 5: Informe y Presentación de Resultados

- **Objetivo:** Traducir los hallazgos técnicos en conocimiento accionable para la toma de decisiones ejecutivas y la remediación técnica.
- **Estructura del Entregable Final:**
 1. **Resumen Ejecutivo:** Dirigido a la alta gerencia; explica el nivel global de riesgo de Aurora Market, las consecuencias comerciales potenciales de las vulnerabilidades descubiertas y una matriz de riesgo simplificada.
 2. **Informe Técnico Detallado:** Dirigido a los desarrolladores y administradores de sistemas. Incluye para cada hallazgo:
 - Clasificación de severidad según el estándar CVSS (Crítica, Alta, Media, Baja).
 - Descripción detallada del vector de ataque y pruebas de concepto paso a paso (Screenshots/Logs).
 - Impacto técnico específico para Aurora Market.
 - Guía paso a paso de remediación técnica y buenas prácticas aplicables.

7. Investigación

- **Metodología elegida: OWASP Web Security Testing Guide (WSTG)**
- **Justificación:** La metodología OWASP WSTG es el estándar de la industria específicamente diseñado tanto para aplicaciones web como e-commerce. Proporciona una guía exhaustiva y estructurada de controles de seguridad a probar (autenticación, gestión de sesiones, validación de entradas, lógica de negocio y pagos), lo que garantiza que no se pase por alto ningún vector de ataque común que pudiera poner en riesgo la tienda Aurora Market.

Dminios clave:

- **WSTG-INFO (Recopilación de Información):** Identificación de motores web, fingerprinting de servidores y archivos sensibles expuestos (robots.txt, .git/).
- **WSTG-ATHN / WSTG-ATHZ (Autenticación y Autorización):** Pruebas de fortaleza en credenciales, derivación de login, y verificación de referencias directas inseguras a objetos (WSTG-ATHZ-02: Testing for IDOR).
- **WSTG-SESS (Gestión de Sesiones):** Evaluación de atributos de cookies de sesión (HttpOnly, Secure, SameSite) y resistencia contra fijación de sesión.
- **WSTG-INJV (Validación de Entradas):** Comprobación metódica contra inyecciones SQL (WSTG-INJV-05), Reflected/Stored XSS (WSTG-INJV-01/02) y Server-Side Template Injection.
- **WSTG-BUSN (Pruebas de Lógica de Negocio):** Verificación de controles anti-fraude en el proceso de pago, manipulación de cantidades/precios e bypass de pasos obligatorios en el flujo del checkout (WSTG-BUSN-01).